

HUONG DAN VIBE CODE WEB DAU GIA TU DONG

Tu y tuong -> UI/UX -> Database -> Backend -> Bao mat -> Hosting -> Domain -> Ban giao

Ban thuc hanh danh cho sinh vien CNTT dung AI Agent/Cursor de tao san pham that

Muc tieu cua file nay

Giup m tao mot web dau gia tu dong co quy trinh ro rang: khong chi code cho chay, ma co san pham, database an toan, backend dung logic, UI/UX tu te, deploy duoc, co domain, co bao mat va co checklist de AI Agent khong pha du an.

Phan	Noi dung
1	Tu duy san pham, PRD va MVP cho web dau gia
2	UI/UX: man hinh, component, design system, user flow
3	Database: bang, quan he, migration, RLS, audit log
4	Backend: API, bidding engine, auto-bid, cron, realtime
5	Bao mat: auth, input, upload, rate limit, payment, logs
6	Hosting, domain, CI/CD, backup, monitoring, ban giao
7	Prompt mau de hoi AI Agent tung phase

Muc luc nhanh

- 1. Chon huong xay dung va pham vi MVP
- 2. Dac ta san pham dau gia tu dong
- 3. Stack khuyen nghi va kien truc tong the
- 4. UI/UX: tu wireframe den giao dien that
- 5. Database va migration: khong de AI pha du lieu
- 6. Backend: luong dau gia, auto-bid, realtime, cron job
- 7. Auth, role, RLS va phan quyen
- 8. Bao mat web dau gia: checklist bat buoc
- 9. Hosting, domain, SSL, env, CI/CD, backup
- 10. Prompt mau cho Cursor/Claude Agent
- 11. Checklist truoc khi public
- 12. Lo trinh 14-21 ngay de build ban MVP

Cach dung file

Moi khi muon lam mot phase, dung prompt mau trong file nay de yeu cau Agent tao output ro rang. Khong bao Agent "lam ca web" ngay tu dau. Moi phase phai co file TASKS.md, test va commit riêng.

1. Chon huong xay dung va pham vi MVP

1.1. Web dau gia tu dong la gi?

- Ngươi bán đang sản phẩm kém giá khởi điểm, giá bước nhảy, thời gian kết thúc, ảnh, mô tả và điều kiện giao dịch.
- Người mua đặt giá. Hệ thống chỉ chấp nhận giá hợp lệ, cao hơn giá hiện tại theo bước nhảy, trước giờ kết thúc.
- Tự động nghĩa là hệ thống tự cập nhật giá hiện tại, tự thông báo người thắng, tự động đóng phiên đấu giá, và có thể có proxy bidding: người mua đặt giá tối đa, hệ thống tự tăng giá thay người đó.
- Bán MVP nên có đấu giá theo thời gian và bid realtime. Proxy auto-bid nên để v2 nếu m chưa vững backend transaction.

1.2. MVP nên làm gì trước?

Mục	Bat buoc o MVP	De sau
Tai khoan	Dang ky, dang nhap, profile co role buyer/seller/admin	KYC nang cao, xac minh CCCD
San pham	Seller tao auction: ten, anh, gia khoi diem, buoc nhay, thoi gian	Goi y AI, review/bao cao vi pham
Dau gia	Dat gia, xem gia hien tai, lich su bid, dem nguoc	Proxy auto-bid, anti-sniping, reserve price
Thong bao	Toast/UI realtime, email thong bao co ban	SMS/push notification
Thanh toan	MVP hoc tap: trang thai pending/manual payment	Cong thanh toan that, marketplace payout
Admin	Duyet/suspend auction, xem log	Dashboard phan tich, fraud scoring

Quy tac vang

Dung build full marketplace ngay. Dau gia co rat nhieu bug nguy hiem: race condition khi 2 nguoi bid cung luc, gia ao, user tu bid san pham cua minh, mat du lieu khi migration, payment dispute. MVP phai hep nhung chac.

1.3. PRD toi thieu truoc khi code

Mau file PRD.md

```
# PRD - Auction Web MVP

## Problem
Nguoi dung can mot noi dang san pham va dau gia minh bach theo thoi gian thuc.

## User roles
- Guest: xem san pham, tim kiem.
- Buyer: dat gia, theo doi phien, xem ket qua.
- Seller: tao phien dau gia, quan ly san pham.
- Admin: duyet, khoa, xu ly tranh chap.
```

MVP features

1. Auth + profile + role.
2. CRUD auction cho seller.
3. Danh sách auction + tìm kiếm + filter.
4. Auction detail + countdown + bid history.
5. Place bid an toàn giao dịch transaction.
6. Auto close ended auctions bằng cron/job.
7. Notification có sẵn.
8. Admin dashboard đơn giản.

Non-goals v1

- Chưa làm payment thật.
- Chưa làm proxy auto-bid nếu transaction chưa chắc.
- Chưa làm mobile app.
- Chưa làm AI valuation.

2. Stack khuyến nghị và kiến trúc tổng thể

2.1. Chọn stack nào?

Stack	Khi nên chọn	Ưu điểm	Rủi ro
Next.js + Supabase + Prisma + Tailwind/shadcn	Muốn vibe nhanh, deploy nhanh, full-stack TypeScript	It file, AI code tốt, có Realtime/Auth/Postgres, hợp MVP	Cần hiểu RLS, server/client boundary, transaction
React + Spring Boot + PostgreSQL + Redis	Muốn luyện Java backend nghiêm túc	Backend chuẩn doanh nghiệp, transaction mạnh, dễ học OOP/REST/Security	Tốc độ vibe chậm hơn, deploy nhiều service hơn
Laravel + MySQL/PostgreSQL	Muốn làm web CRUD nhanh, admin nhanh	Ecosystem mature, migration tốt	Không sát Java/TS stack của mình

Khuyến nghị cho mình

Nếu mục tiêu là có web đầu giá chạy được nhanh: Next.js + Supabase/Postgres + Prisma + Tailwind + shadcn. Nếu mục tiêu là học backend Java thật chất: React + Spring Boot + PostgreSQL + Redis. File này viết theo kiến trúc chung, có thể áp dụng cho cả hai.

2.2. Kiến trúc tổng thể

[Browser]

- > UI pages/components
- > Auth session cookie/JWT
- > Server Actions or API Routes
 - > Validation layer (Zod/DTO)
 - > Authorization layer (role + ownership)
 - > Business service (AuctionService, BidService)
 - > Transaction layer (Postgres/Prisma/JPA)
 - > Realtime event + notification
- > Database PostgreSQL
- > Object Storage for images
- > Background job/cron to close auctions
- > Email/payment provider if needed

Production infra:

Vercel/Render/Fly/Railway + Supabase/Neon/Postgres + Cloudflare DNS + GitHub Actions + Monitoring

2.3. Cấu trúc thư mục nếu dùng Next.js

```
auction-web/  
  app/  
    (public)/page.tsx
```

auctions/page.tsx
auctions/[id]/page.tsx
seller/dashboard/page.tsx
admin/page.tsx
api/bids/route.ts
api/cron/close-auctions/route.ts
components/
 auction/AuctionCard.tsx
 auction/BidPanel.tsx
 auction/CountdownTimer.tsx
 layout/Navbar.tsx
 ui/...
lib/
 auth.ts
 db.ts
 validators.ts
 rate-limit.ts
 realtime.ts
server/
 auctions.service.ts
 bids.service.ts
 notifications.service.ts
prisma/
 schema.prisma
 migrations/
docs/
 PRD.md
 TASKS.md
 SECURITY_CHECKLIST.md
 CURSOR_RULES.md

3. UI/UX: tu wireframe den giao dien that

3.1. Nguyen tac UI/UX cho web dau gia

- Gia hien tai, thoi gian con lai, nut dat gia phai la 3 thong tin noi bat nhat tren trang chi tiet.
- Trang dau gia phai tao cam giac tin cay: anh ro, seller verified, lich su bid minh bach, dieu kien giao dich ro.
- Khong lam UI qua mau me. Dung design system de AI khong tao CSS loi thoi.
- Moi hanh dong nguy hiem can confirm: dat gia, huy phien, suspend user, dong phien.
- Loi validation phai hien tai cho: bid thap qua, phien da ket thuc, dang nhap truoc khi bid, khong duoc bid san pham cua minh.
- Mobile-first: nguoi dung dau gia thuong xem tren dien thoai. Bid panel tren mobile nen sticky o duoi.

3.2. Bo man hinh can co

Man hinh	Thanh phan UI can co	Luu y UX
Landing	Hero, search, category, featured auctions, how it works	Giai thich dau gia trong 3 buoc de user moi khong roi
Auction list	Filter status/category/price, sort ending soon, card grid	Card phai co countdown, current price, bid count
Auction detail	Gallery, title, price, countdown, bid form, bid history, seller info	Bid form gan gia hien tai, co quick increments
Seller dashboard	My auctions, create/edit, status, winner	Chi cho edit truoc khi co bid hoac khi draft
Admin dashboard	Users, auctions, reports, audit log	Dung Ant Design/MUI neu can table/filter nhanh
Auth	Login/register, forgot password	Thong bao loi chung chung, khong tiet lo email ton tai hay khong

3.3. Design system nen ep AI dung

Lua chon	Dung khi nao	Prompt nen noi
Tailwind + shadcn/ui	App modern, can UI dep va tuy bien	Dung component shadcn/ui, Tailwind utility, khong viet CSS global tuy tien
Ant Design	Admin dashboard nhieu table/filter/form	Dung antd Table, Form, Modal, Tag, Statistic,

		DatePicker
Material UI	Muốn UI on dinh, production ready, component day du	Dung MUI theme, spacing system, responsive breakpoints

Prompt UI/UX cho Agent:

Mày là Senior Product Designer + Frontend Engineer.
Hãy thiết kế giao diện cho web đấu giá theo phong cách hiện đại, tin cậy, mobile-first.
Bắt buộc dùng Tailwind + shadcn/ui, không viết CSS thủ công rối rắm.

Màn hình cần code: Auction Detail Page.
Các thành phần bắt buộc:

- gallery ảnh sản phẩm
- current price thật nổi bật
- countdown timer
- form đặt giá với quick increment
- bid history realtime
- seller trust card
- warning nếu phiên sắp kết thúc

Trước khi code, hãy liệt kê component tree và states cần quản lý.
Sau đó chỉ sửa các file liên quan, không refactor toàn project.

Meo dung anh tham khảo

Chup man hinh mot UI dep, gan vao Cursor/Claude, roi yeu cau: "Hay code chuc nang A dua tren phong cach thiet ke trong anh, nhung van dung component hien tai cua du an." Dung anh de lay style, khong copy thuong hieu/logo.

4. Database va migration: khong de AI pha du lieu

4.1. Cac bang cot loi

Bang	Muc dich	Truong quan trong
profiles	Thong tin user mo rong	id, email, display_name, role, reputation, created_at
auctions	Phien dau gia	id, seller_id, title, status, starts_at, ends_at, start_price, current_price, bid_increment, winner_id
auction_images	Anh san pham	id, auction_id, url, sort_order
bids	Lich su dau gia	id, auction_id, bidder_id, amount, created_at, status
proxy_bids	Gia toi da tu dong	id, auction_id, bidder_id, max_amount, active
watchlist	Theo doi san pham	user_id, auction_id, created_at
orders	Ket qua sau khi thang	id, auction_id, buyer_id, seller_id, final_price, status
payments	Thanh toan	id, order_id, provider, amount, status, provider_ref
notifications	Thong bao	id, user_id, type, title, read_at
audit_logs	Truy vet hanh dong	id, actor_id, action, entity_type, entity_id, metadata

4.2. Quy tac database bat buoc

- Khong sua DB thu cong tren production. Moi thay doi schema phai qua migration file.
- Khong cho AI chay DROP DATABASE, TRUNCATE, reset migration tren database that.
- Them constraint o DB, khong chi validate o frontend: amount > 0, ends_at > starts_at, role hop le, status hop le.
- Bid can transaction. Neu 2 nguoi bid cung luc, DB phai khoa dong auction hoac dung isolation hop ly.
- Gia hien tai nen duoc cap nhat trong transaction cung voi insert bid.
- Lich su bid khong nen xoa. Neu can an thi status = rejected/cancelled va ghi audit_log.
- Anh upload vao object storage, DB chi luu URL/path, khong luu file binary lon trong DB.

4.3. Schema mau rut gon

```
Auction
- id: uuid
- seller_id: uuid -> profiles.id
- title: text
- description: text
- category: text
- start_price: decimal
- current_price: decimal
- bid_increment: decimal
- status: DRAFT | ACTIVE | ENDED | CANCELLED | SUSPENDED
- starts_at: timestamptz
- ends_at: timestamptz
- winner_id: uuid nullable
- created_at, updated_at

Bid
- id: uuid
- auction_id: uuid -> auctions.id
- bidder_id: uuid -> profiles.id
- amount: decimal
- status: ACCEPTED | REJECTED | CANCELLED
- created_at

Important indexes:
- auctions(status, ends_at)
- auctions(seller_id, status)
- bids(auction_id, amount desc)
- bids(bidder_id, created_at desc)
```

4.4. Migration workflow

- 13. Agent de xuất thay doi schema bang text truooc.
- 14. M duyet: co mat du lieu khong, co can backfill khong, co anh huong production khong.
- 15. Agent tao migration file, khong chay len production.
- 16. Chay migration tren local/staging truooc.
- 17. Backup database production.
- 18. Chay migrate deploy tren production qua CI/CD hoac lenh co kiem soat.
- 19. Kiem tra smoke test: tao auction, bid, close auction, xem dashboard.

```
Prompt migration an toan:

Hãy đề xuất migration cho yêu cầu: [mô tả thay đổi].
Quy tắc:
- Không được dùng DROP/TRUNCATE/RESET.
- Nếu đổi tên cột, hãy dùng chiến lược an toàn: add column -> backfill -> switch code -> remove later.
- Trước khi viết migration, hãy liệt kê rủi ro mất dữ liệu.
- Chỉ tạo file migration, không tự chạy trên production.
- Cập nhật schema, seed test và test case liên quan.
```

5. Backend: bidding engine, auto-bid, realtime, cron

5.1. API/Action can co

Nhom	Endpoint/Action	Quy tac
Auction	GET /auctions	Public, co filter/sort/pagination
Auction	POST /auctions	Seller only, validate input, draft hoac active
Auction	PATCH /auctions/:id	Chi seller owner/admin, han che sua khi da co bid
Bid	POST /auctions/:id/bids	Auth required, transaction, rate limit, forbid self-bid
Bid	GET /auctions/:id/bids	Public hoac auth, pagination, an thong tin

		nhay cam
Proxy	POST /auctions/:id/proxy-bid	v2, luu max_amount rieng tu, khong public
Cron	POST /api/cron/close-auctions	Secret cron token, auto close phien het gio
Admin	POST /admin/auctions/:id/suspend	Admin only, audit log

5.2. Logic dat gia an toan

Pseudo-flow: placeBid(auctionId, userId, amount)

1. Require login.
2. Validate amount la number, duong, dung currency precision.
3. Rate limit theo userId + IP.
4. Open DB transaction.
5. Lock auction row: SELECT ... FOR UPDATE.
6. Check auction.status == ACTIVE.
7. Check now between starts_at and ends_at.
8. Check userId != seller_id.
9. Check amount >= current_price + bid_increment.
10. Insert bid ACCEPTED.
11. Update auctions.current_price = amount, winner_id = userId.
12. Optional anti-sniping: if ends_at - now < 2 minutes, extend ends_at.
13. Insert audit_log.
14. Commit transaction.
15. Publish realtime event + notification.

Race condition la loi nguy hiem nhat

Neu 2 nguoi cung dat gia cung luc, code binh thuong co the chap nhan ca 2 bid sai logic. Vi vay placeBid phai dung transaction + lock hoac co che atomic update. Dung chi check current_price o frontend.

5.3. Auto-bid/proxy bidding nen lam the nao?

- Proxy bidding la viec nguoi mua dat max_amount rieng tu. He thong tu tang gia theo buoc nhay de giu nguoi do dang dan dau, nhưng khong vuot max_amount.
- Khong public max_amount. Chi public bid amount hien tai.
- Neu co 2 proxy_bids, he thong so sanh max_amount cao nhat va nhi cao nhat de tinh current_price moi.
- Nen lam sau khi placeBid thuong da chac, vi proxy bid can transaction phuc tap hon.
- Can audit log vi user co the khieu nai: tai sao he thong tu tang gia.

Rule don gian cho proxy bidding:

- A dat max 1,000,000. Current price = 100,000.
- B dat bid 300,000.
- He thong co the tu dat gia cho A = min(300,000 + increment, 1,000,000).
- Neu B dat max 1,200,000, B se vuot A va current price = 1,000,000 + increment.

Luu y: day la logic kinh doanh, phai test bang nhieu case.

5.4. Cron/job dong phien dau gia

- Moi 1 phut chay job tim auctions ACTIVE co ends_at <= now va status chua ENDED.
- Trong transaction: lock auction, lay highest bid, set winner_id, status ENDED, tao order pending payment, gui notification.
- Job phai idempotent: chay lai 2 lan khong tao 2 orders.
- Endpoint cron phai co secret token, khong public ai cung goi duoc.

6. Auth, role, RLS va phan quyen

6.1. Co nen de AI viet he Auth?

- Khong nen de AI tu viet auth tu dau neu lam san pham that. Nen dung provider/framework uy tin: Supabase Auth, Clerk, Auth.js, Spring Security, Firebase Auth...

- AI có thể ghép auth vào app, viết middleware, role check, protected route, nhưng m phải bắt nó giải thích luồng session/token.
- Không tu lưu password plaintext. Nếu tu làm backend, password phải hash bằng thuật toán phù hợp, có salt, và dùng thu viên uy tín.
- Mọi API quan trọng phải check auth ở server. Frontend hide button không phải bảo mật.
- Admin role không được lấy từ client. Role phải đọc từ DB/session server-side.

6.2. Phân quyền role

Hành động	Guest	Buyer	Seller	Admin
Xem auction public	Có	Có	Có	Có
Dat gia	Không	Có	Có, nhưng không được bid của mình	Có nếu policy cho phép
Tạo auction	Không	Không/Có nếu cho phép	Có	Có
Sửa auction	Không	Không	Chỉ auction của mình và chưa có bid	Có
Suspend auction/user	Không	Không	Không	Có
Xem audit log	Không	Không	Không	Có

6.3. Có nên bắt RLS?

Câu trả lời

Neu dung Supabase/Postgres với client có thể gọi database/realtime, nên bắt RLS cho các bảng có dữ liệu user. RLS là lớp phòng thủ sau cùng: kể cả code frontend/API bị gọi sai, DB vẫn chặn user đọc/sửa dòng không thuộc về mình.

- profiles: user chỉ update profile của mình; admin được xem nhiều hơn.
- auctions: public được xem ACTIVE; seller được xem/sửa auction của mình; admin được xem/sửa tất cả.
- bids: user được insert bid của mình nếu auction active; public có thể xem amount/time nhưng nên ẩn thông tin nhạy cảm.
- proxy_bids: chỉ owner và service role được xem. Tuyet doi không public max_amount.
- payments/orders: buyer/seller liên quan và admin mọi được xem.

Prompt RLS:

Hãy viết policy RLS cho các bảng profiles, auctions, bids, proxy_bids, orders.

Yêu cầu:

- Mỗi policy phải nói rõ role nào được SELECT/INSERT/UPDATE/DELETE.
- Không public proxy_bids.max_amount.
- Không cho seller bid sản phẩm của chính mình.
- Không cho user sửa bid history.
- Viết test case chứng minh user A không đọc được dữ liệu riêng của user B.

6.4. Làm sạch input của user

- Định nghĩa schema validate ở server: title min/max length, price decimal, date future, category enum, image type/size.
- Dùng allowlist thay vì blacklist: category chỉ nằm trong danh sách cho phép.
- Escape/sanitize nội dung rich text nếu cho phép HTML. Tốt nhất MVP chỉ cho plain text/Markdown an toàn.
- Ảnh upload: chỉ cho mime type hợp lệ, giới hạn dung lượng, đổi tên file, lưu storage path, không tin filename user.
- Mọi request mutation phải có auth + authorization + validation + rate limit.

7. Bảo mật web đầu giá: checklist bắt buộc

7.1. Threat model cho web đầu giá

Nguy cơ	Ví dụ	Cách phòng
Bid gian lận	User sửa amount trên request, bid sau giờ kết thúc	Server validation + transaction + server time
Race condition	2 bid cùng lúc làm current_price sai	DB lock/transaction, unique/idempotency
Access control lỗi	User sửa auction_id của người khác	Check owner/admin trên server + RLS
XSS	Mô tả sản phẩm chèn script	Escape output, sanitize rich text, CSP
SQL injection	Filter/search truyền SQL	ORM/query parameter, không nối chuỗi SQL
Brute force / spam bid	Bot bid liên tục	Rate limit, captcha với luồng nhạy cảm
Upload độc hại	File ảnh giả mạo/malware	Validate type/size, storage private/public rules

Lộ secrets	.env bị commit lên GitHub	.gitignore, secret scanning, env vars trên hosting
Payment fraud	Webhook giả mạo, payment status sai	Verify webhook signature, idempotency, logs

7.2. Rate limit nên đặt ở đâu?

- Login/register: giới hạn theo IP + email để chống brute force.
- Place bid: giới hạn theo userId + auctionId + IP. Ví dụ 10-30 bid/phút/user tùy sản phẩm.
- Create auction/upload image: giới hạn theo userId để chống spam storage.
- Cron endpoint: chỉ cho secret token/hosting scheduler gọi.
- Admin actions: bắt buộc audit log và có thể yêu cầu re-auth nếu nguy hiểm.

Prompt rate limit:

Hãy thêm rate limit cho các mutation sau: login, register, create auction, upload image, place bid.

Yêu cầu:

- Key theo userId nếu đã login, fallback theo IP nếu chưa login.
- Place bid phải key theo auctionId + userId.
- Khi bị limit, trả error rõ nhưng không leak thông tin nhạy cảm.
- Viết test mô phỏng gửi nhiều request liên tục.
- Không làm ảnh hưởng GET public list quá nặng.

7.3. .gitignore và secrets

.gitignore tối thiểu cho web project

node_modules/

.next/

dist/

build/

.env

.env.*

!.env.example

.DS_Store

coverage/

.vercel/

*.log

nếu dùng Java/Spring

/target/

*.class

.idea/

*.iml

uploads local

uploads/

storage/

- Luôn có .env.example để Agent biết biến môi trường cần thiết nhưng không có secret thật.
- Không paste API key thật vào prompt. Nếu cần, đặt tên biến môi trường và mô tả cách lấy.
- Nếu lo secret trên GitHub, phải rotate secret, không chỉ xóa commit.
- Production, staging, local phải dùng secret riêng.

7.4. Prompt review bảo mật tiết kiệm token

Prompt review bảo mật theo phạm vi nhỏ:

Chỉ review các file sau: [liệt kê file].

Ngữ cảnh: chức năng [place bid / upload image / auth middleware].

Hãy tìm lỗi theo 5 nhóm:

1. Auth/authorization
2. Input validation
3. Race condition/transaction

- 4. Secrets/logs
- 5. Abuse/rate limit

Output dạng bảng: Risk | File | Dòng/đoạn liên quan | Vì sao nguy hiểm | Cách sửa ngắn nhất.
Không refactor code. Không đọc toàn project nếu không cần.

Co the nho AI "hack" web minh khong?

Co the nho AI lap ke hoach pentest hop phap cho web cua chinh m, review code, viet test case,kiem tra checklist va huong dan dung tool nhu OWASP ZAP. Khong dung AI de tan cong website/nguoi khac, brute force, bypass thanh toan, lay du lieu that. Chi test tren local/staging/production ma m co quyen.

8. Hosting, domain, SSL, env, CI/CD, backup

8.1. Phuong an hosting

Thanh phan	Phuong an de vibe nhanh	Phuong an nang cao
Frontend/Next.js	Vercel	Cloudflare Pages/Workers, Fly.io, VPS
Backend Java	Render/Railway/Fly.io	VPS Docker + Nginx
Database	Supabase Postgres/Neon/Railway Postgres	Managed Postgres riêng + read replica
Storage anh	Supabase Storage/Cloudflare R2	S3 compatible storage + CDN
Realtime	Supabase Realtime/WebSocket backend	Redis PubSub + WebSocket service
Email	Resend/Brevo/SendGrid	SMTP/domain verified + templates
Domain/DNS	Cloudflare DNS	DNS provider + CDN/WAF

8.2. Cac moi truong

Moi truong	Dung de lam gi	Luu y
local	Code tren may	Dung .env.local, database local/dev, co seed data
staging	Test nhu production truoac khi public	Dung domain phu, DB riêng, secrets riêng
production	Nguoi dung that	Khong test lung tung, co backup, monitoring, audit log

8.3. Checklist deploy

- Repo da co README: cach run local, env vars, lenh migrate, lenh test.
- CI chay lint/test/build truoac khi merge main.
- Env vars da set tren hosting, khong commit .env.
- Migration da chay tren staging truoac production.
- Database production da bat backup tu dong neu provider ho tro.
- Domain tro dung hosting, SSL active, www redirect ve apex hoac nguoc lai.
- Cron close-auctions da cau hinh va co secret.
- Logging/monitoring loi server da bat.
- Tai khoan admin dau tien tao bang script an toan, khong hard-code trong code.

Prompt deploy:

Hãy tạo checklist deploy production cho project này.

Bắt buộc gồm:

- env vars cần set
- database migration command
- build command
- cron endpoint và cách bảo vệ bằng secret
- domain/DNS/SSL
- smoke test sau deploy
- rollback plan nếu deploy lỗi

Không được giả định secret thật. Dùng tên biến trong .env.example.

9. Workflow vibe coding từ đầu đến cuối

9.1. Luôn chia phase

Phase	Dau ra can co	Khong cho AI lam
0 - Research/PM	PRD.md, MVP, user flow, non-goals	Code ngay khi chua co luong
1 - UI kit	Design tokens, layout, component list	Viet CSS lung tung moi file
2 - DB	ERD, schema, migration, seed	Sua DB production, drop/reset
3 - Auth/roles	Protected routes, role checks, RLS/policies	Tu viet auth handmade neu khong can
4 - Auction CRUD	Create/list/detail/edit auction	Tron business logic vao UI
5 - Bidding engine	placeBid transaction + tests	Update current price khong transaction
6 - Realtime/cron	Bid updates, close auctions job	Cron public khong secret
7 - Admin/security	Admin dashboard, audit logs, rate limit	Bo qua logs va monitoring
8 - Deploy	Hosting, domain, env, backup, smoke test	Deploy thang len prod khong staging

9.2. File điều khiển AI Agent

```
# CURSOR_RULES.md / CLAUDE.md

## Project goal
Build an auction web app with secure bidding, clear UI, and production-ready deployment.

## Rules
1. Do not modify production data or run destructive DB commands.
2. Always propose a plan before coding large changes.
3. Keep changes small and scoped to requested files.
4. All user input must be validated on server.
5. All protected actions require auth + authorization.
6. All bidding changes must use DB transaction and tests.
7. Never expose secrets, proxy max bids, payment provider refs, or service role keys.
8. Use existing design system: Tailwind + shadcn/ui.
9. After each phase, update TASKS.md and list manual tests.
10. If unsure, ask before changing architecture.

## Coding style
- TypeScript strict mode / Java strict DTO validation.
- No raw SQL string concatenation.
- Prefer service layer for business logic.
- Prefer migrations over manual schema edits.
```

9.3. Prompt tổng đề bắt đầu dự án

```
Mày là Tech Lead + Product Manager + Security Reviewer.
Tao muốn build web đấu giá tự động MVP.
Stack đề xuất: [Next.js + Supabase + Prisma + Tailwind/shadcn] hoặc [React + Spring Boot + PostgreSQL].

Trước khi code, hãy tạo kế hoạch gồm:
1. PRD ngắn gọn.
2. User roles và user flow.
3. Danh sách màn hình UI/UX.
4. Database schema sơ bộ.
5. API/action list.
6. Security checklist riêng cho đấu giá.
7. Phase plan trong TASKS.md.

Chỉ tạo tài liệu và skeleton project, chưa viết bidding engine phức tạp.
Hỏi lại tao nếu thiếu thông tin quan trọng.
```

9.4. Prompt cho bidding engine

```
Chỉ tập trung vào chức năng place bid.
```

Hãy đọc các file: [bids.service.ts], [auction schema], [validators].

Yêu cầu:

- Server-side validation.
- Auth required.
- Không cho seller bid sản phẩm của mình.
- Không cho bid sau khi auction hết hạn.
- Bid amount $\geq$ current_price + bid_increment.
- Dùng transaction/row lock để chống race condition.
- Insert bid + update current_price + winner_id trong cùng transaction.
- Thêm audit_log.
- Viết test cho 5 case: bid hợp lệ, bid thấp, bid sau giờ, seller self-bid, 2 bid đồng thời.
- Không sửa UI trong phase này.

9.5. Prompt cho UI detail page

Chỉ code trang Auction Detail.

Dùng Tailwind + shadcn/ui, mobile-first, giao diện hiện đại.

Không tự tạo design system mới.

Component cần có:

- AuctionImageGallery
- AuctionStatusBadge
- CountdownTimer
- CurrentPriceCard
- BidForm
- BidHistory
- SellerInfoCard
- WatchlistButton

States cần xử lý:

- loading
- ended
- unauthenticated
- bid too low
- bid accepted
- realtime new bid
- network error

Sau khi code, liệt kê test thủ công trên desktop và mobile.

10. Testing và QA cho web đấu giá

Loại test	Cần test gì	Vì sao quan trọng
Unit test	Tính giá hợp lệ, bid increment, countdown utils	Bat lỗi logic nhỏ
Integration test	placeBid với DB transaction	Bat race condition/co số dữ liệu
E2E test	User login -> xem auction -> bid -> thay giá mới	Dam bảo luồng chạy
Concurrency test	2-10 user bid cùng lúc	Dau giá rat de loi khi dong thoi
Security test	User A sua auction User B, self-bid, spam bid	Bat lỗi auth/authorization
Deploy smoke test	Homepage, list, detail, create auction, bid, cron	Dam bao deploy khong hong

10.1. Test case bat buoc cho placeBid

- Bid 150k khi current 100k, increment 10k -> accepted.
- Bid 105k khi current 100k, increment 10k -> rejected.
- Bid khi status ENDED -> rejected.
- Seller bid auction của mình -> rejected.
- Guest bid -> redirect/login error.
- 2 bid đồng thời 200k và 210k -> current_price cuối cùng = 210k, winner dùng.

- Bid trong 1 phút cuối nếu có anti-sniping -> ends_at được gia hạn đúng.
- User spam 100 request/phút -> bị rate limit.

10.2. Checklist trước khi public

Hang mục	Dat khi
UI/UX	Mobile không vỡ layout, button bid rõ, error hiển tại chỗ, skeleton/loading có
Auth	Mọi protected route/action check server-side, role admin không đọc từ client
DB	Migration chạy staging, backup prod, không có DROP nguy hiểm
Bidding	Transaction + concurrency test pass
RLS/Authorization	User không đọc/sửa dữ liệu không thuộc về mình
Security	Rate limit, input validation, upload validation, secrets không leak
Payment	Webhook verify signature, idempotency nếu có payment that
Deploy	Env vars, domain, SSL, cron, logs, monitoring đã set
Legal/Trust	Điều khoản sử dụng, chính sách giao dịch, report/suspend flow

11. Lộ trình 14-21 ngày build MVP

Ngày	Việc làm	Output
1	Làm PRD, user flow, scope MVP	docs/PRD.md, docs/TASKS.md
2	Chọn stack, tạo project, setup UI kit	Repo chạy local, layout có ban
3	Thiết kế DB schema + migration đầu tiên	profiles, auctions, bids, images
4	Auth + role + protected routes	login/register/profile
5	Seller create/list auctions	CRUD auction draft/active
6	Auction list + detail page UI	Card grid, detail page, countdown
7	Place bid backend transaction	Bid service + tests
8	BidForm + bid history realtime	UI data gia chạy
9	Cron close auctions + create order	Ended auction flow
10	Admin dashboard có ban	Suspend auction/user, audit log
11	Security pass 1	Input validation, rate limit, RLS/policies
12	Testing pass	Unit/integration/e2e có ban
13	Staging deploy	Staging URL, env, migration
14	Domain + production deploy + smoke test	Website public MVP
15-21	Polish UI, notification, payment/manual payment, docs ban giao	Ban có the demo/ban cho khách

12. Nguồn docs chính thức nên đưa cho AI đọc

- Next.js docs - App Router, Server Components, Server Actions, data mutation.
- Supabase docs - Auth, Postgres, Row Level Security, Realtime, Storage.
- Prisma docs - Prisma Migrate, production migration workflow.
- Tailwind CSS docs - Next.js installation, utility-first styling.
- shadcn/ui docs - Next.js installation and component usage.
- Ant Design / Material UI docs - admin dashboard/table/form component patterns.
- OWASP Cheat Sheet Series - Input Validation, Session Management, CSRF, Top 10.
- GitHub Actions docs - secrets, environments, CI/CD.
- Vercel/Cloudflare docs - deployment, custom domains, DNS, SSL.
- Stripe Connect docs - marketplace payments if project has real payment/payout.

Lưu ý pháp lý và thanh toán

Dấu gia thất liên quan đến tiền, tranh chấp, hoàn tiền, vận chuyển, thuê, điều khoản sử dụng và quy định của từng quốc gia. Nếu làm sản phẩm thất, cần kiểm tra pháp lý và payment provider phù hợp. Ban MVP học tập nên dùng payment manual/pending trước.

13. Ban tóm tắt để dán vào Cursor mỗi lần làm

Context dự án:

Tạo đang build web đấu giá tự động. Nguyên tắc quan trọng:

- UI dùng Tailwind + shadcn/ui, mobile-first.
- DB dùng migration, không sửa production thủ công.
- Bidding phải transaction, không update current_price bừa.

- Auth/role check server-side, không tin client.
- Có RLS nếu dùng Supabase.
- Mọi input user phải validate server-side.
- Có rate limit cho login, create auction, upload, place bid.
- Secrets để trong env, không commit .env.
- Mỗi phase phải update TASKS.md và viết test.

Nhiệm vụ phase hiện tại: [ghi rõ]

Phạm vi file được sửa: [liệt kê]

Không được làm: [liệt kê]

Trước khi code, hãy tóm tắt kế hoạch 5-7 dòng.

Sau khi code, hãy liệt kê test thủ công và rủi ro còn lại.

Phu luc A - Mau .env.example

```
# App
APP_URL=http://localhost:3000
NODE_ENV=development

# Database
DATABASE_URL=postgresql://user:password@localhost:5432/auction_dev

# Auth provider
AUTH_SECRET=replace_me
NEXT_PUBLIC_SUPABASE_URL=replace_me
NEXT_PUBLIC_SUPABASE_ANON_KEY=replace_me
SUPABASE_SERVICE_ROLE_KEY=replace_me_server_only

# Storage
STORAGE_BUCKET=auction-images

# Realtime / Redis / Rate limit
REDIS_URL=replace_me
RATE_LIMIT_SECRET=replace_me

# Cron
CRON_SECRET=replace_me

# Email
EMAIL_PROVIDER_API_KEY=replace_me
EMAIL_FROM=no-reply@example.com

# Payment optional
PAYMENT_PROVIDER_SECRET=replace_me
PAYMENT_WEBHOOK_SECRET=replace_me
```

Phu luc B - Cau hoi can tra loi truoc khi code that

- Dau gia co cho seller sua auction sau khi da co bid khong?
- Co gia san/reserve price khong?
- Co anti-sniping khong? Neu co, gia han bao lau?
- Bid increment co co dinh hay tuy theo khoang gia?
- Co cho buy-now khong?
- Thanh toan: manual, COD/chuyen khoan, hay tích hop provider?
- Neu winner khong thanh toan thi xu ly the nao?
- Seller co can duyet/KYC truoc khi dang san pham khong?
- Ai chiu phi van chuyen?
- Can admin duyet auction truoc khi public khong?

Phu luc C - Dinh nghia Done cho mot phase

- Code chay local khong loi.
- Da co validation o server.
- Da co authorization check neu lien quan user data.
- Da co test toi thieu cho case thanh cong va case loi.
- Da update TASKS.md/README neu them lenh/env moi.
- Da review security nho theo pham vi file vua sua.
- Da commit riêng phase, message ro rang.